

第 10 章 信息系统安全管理作业

填空题：

1. ISO/IEC 27001 标准，采用“计划 (P)—实施 (D)—检查 (C)—处置 (A)” (PDCA) 模型去架构所有信息系统管理体系的流程。
2. 信息系统安全管理的类型包括物理安全管理、系统安全管理、运行安全管理、数据安全管理、人员安全管理和技术文档安全管理。
3. 信息系统安全等级保护是从与信息系统安全相关的物理层面、网络层面、系统层面、应用层面和管理层面对信息和信息系统实施分等级保护。

选择题：

1. 信息系统安全管理措施中的运行安全管理不包括 (C)
A. 故障管理 B. 性能管理 C. 配置管理 D. 变更管理
2. 不属于信息系统安全管理措施主要类型的是 (B)
A. 管理控制 B. 访问控制 C. 技术控制 D. 物理控制
3. 属于信息系统安全管理措施中的人员安全管理原则之一是 (A)
A. 最小特权原则 B. 全员参与原则 C. 主要领导负责原则 D. 分权与授权原则
4. 启动 PDCA 循环的启动器应具有哪些条件 (ACDE)
A. 提供必需的资源 B. 确定管理范围 C. 选择风险管理方法 D. 确定评审方法 E. 文件化实践
5. PDCA 模型处置阶段可能持续进行以下哪些操作 (ABCD)
A. 测量信息系统安全管理体系满足安全方针和目标方面的业绩；
B. 识别信息系统安全管理体系的改进，并有效实施；
C. 采取适当的纠正和预防措施；
D. 针对结果，进行及时沟通，并与所有相关方磋商；
E. 记录并报告影响安全管理体系有效性的活动和事件。

简答题：

1. 信息系统安全管理的概念和五个组成要素（要素需简答说明）

答：

- (1) 概念：信息系统安全管理指计划、组织、领导、控制等环节来协调人力、物力、财力等资源，从而保证组织内的信息系统以及信息处理的安全；
- (2) 五个要素是：管理的主体、管理的客体、管理手段、管理环境、管理目标
 - a) 管理主体：指信息系统的安全由谁来管理；
 - b) 管理客体：指管理的对象是谁；
 - c) 管理手段：指管理流程、管理制度和管理方法；
 - d) 管理环境：指在什么情况、什么环境和什么条件下对信息系统安全实施管理；
 - e) 管理目标：指要达到的管理结果。

2. 如何理解信息系统安全管理中的分权和授权原则

答：

对特定职能或责任领域的管理功能实施分离、独立审计等分权，避免权力过于集中所带来的隐患，以减少未授权的修改或滥用系统资源的机会。任何实体（如用户、管理员、进

程、应用或系统)仅享有该实体需要完成其任务所必需的权限,不应享有任何多余权限。

3. 在信息系统安全管理措施中阐述的物理安全管理,与第 3 章的物理安全之间是什么关系? 分析说明

答:

(1) 第 3 章的物理安全包含信息系统安全管理措施中的物理安全管理概念;

(2) 信息系统安全管理措施中的物理安全管理是第三章物理安全这一概念的具体实现;

分析: 第 3 章物理安全的内涵更加丰富,不仅包括设备安全、环境安全和系统物理安全的定义,还包括具体的防护技术和管理标准和方法。信息系统管理措施中的物理安全管理仅仅包含物理安全的定义和管理方面的要求。